$ ./talk --topic=state_trojan

State Trojan

The Malware with a Warrant

Pietro Boccaletto · Francesco Infantini

Rome · 03/10/2026

ROMHACK 2026 CAMP



// all glory to the hypnotoad

$ whoarewe

~/pietro



Pietro Boccaletto, PhD

@peterwander

CTO @ AptGetDefence
Adjunct Prof @ UniPD

~/francesco



Francesco Infantini

@spawntty

Red Team Lead @ AptGetDefence

>_apt/get.defence

The perfect spying device…



…is sitting in your pocket.

Microphone. Camera. GPS. Diary. Wallet. Authenticator. The most honest archive of your life.

(AI-generated. Daniel Craig did not sponsor this talk.)

How much of a person are we authorizing someone to access?



What's a "captatore informatico"?



a.k.a. the State Trojan

Software implanted on an electronic device to enable investigative **interception and collection.**

art_266_cpp.txt

Art. 266 c.p.p.

Expressly contemplates interception of communications between persons, carried out by inserting a captatore into a portable electronic device.

art_266-bis_cpp.txt

Art. 266-bis c.p.p.

Separately regulates the interception of computer or telematic communications.

Interception: the good old way

threat_model_v1.png



> Authorized MitM

An authorized man-in-the-middle, with the kind cooperation of the telco.

> On the wire

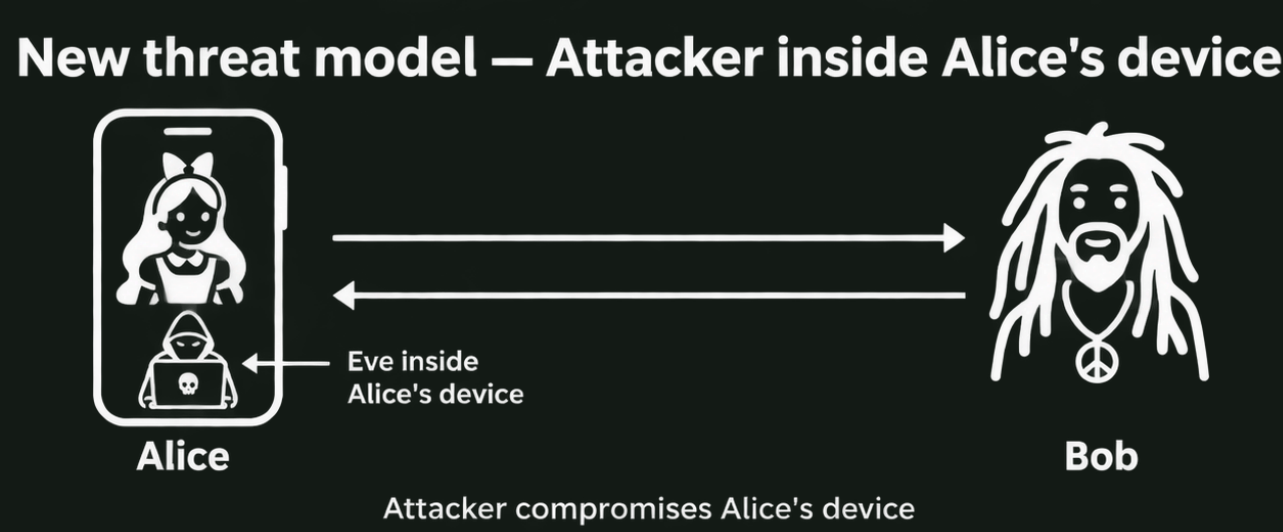
You intercept the communication while it travels through the channel.

> Then came E2EE

Encrypted end to end, the traffic in the middle becomes far less useful.

Interception: now

threat_model_v2.png



> Inside the endpoint

The interception point moves from the channel to the device itself.

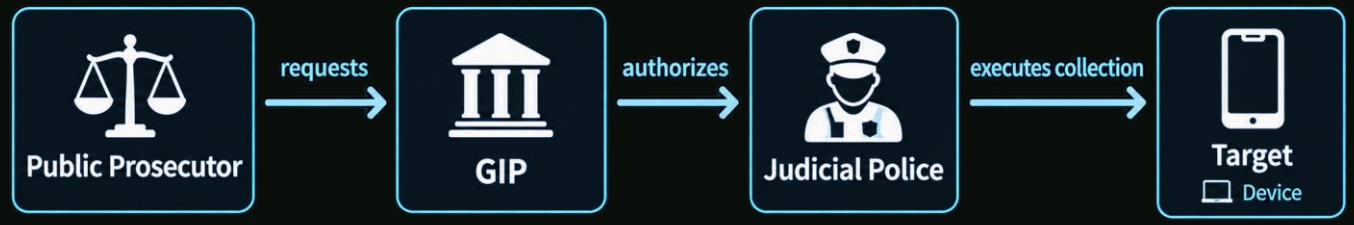
> Where plaintext lives

Collect before encryption, after decryption, or straight from the app or OS.

> Encryption? Bypassed

No need to break the crypto when you sit where it's decrypted.

Who can legally deploy it?



art_267_cpp.txt

Serious indications of a crime, and interception must be absolutely indispensable.

The Public Prosecutor requests authorization from the GIP, who must issue a reasoned decision. The prosecutor then carries out the operation directly or through the judicial police.

applicable_offences.txt

- Serious non-negligent crimes punishable by more than five years' imprisonment
- Drug-related offences
- Mafia / organized crime
- Terrorism
- Certain serious offences against the Public Administration

When the tool works as intended

case_caccia.md

Bruno Caccia / 'Ndrangheta



- 1983 — Turin Chief Prosecutor Bruno Caccia murdered by the 'Ndrangheta
- Trojan interceptions provided key evidence against Rocco Schirripa
- 2020 — life sentence becomes final

case_milan.md

Milan logistics investigation



>>>ANSA/ Per 20 anni evadono il fisco, scoperti grazie al trojan

Indagine della procura di Milano.I pm:'intercettazioni decisive'

Redazione ANSA
MILANO
28 marzo 2023
19:11
STORIA

(di Igor Greganti) (ANSA) - MILANO, 28 MAR - Mentre si discute a livello politico di limitare l'utilizzo delle intercettazioni, la Procura di Milano rivendica come il sistema del trojan, captatore informatico che viene inserito nei telefoni degli indagati e che li trasforma in microspie, sia stato "fondamentale" in un'ultima inchiesta che ha

- 2023 — logistics cooperatives and financial crime: false invoices, bankruptcy fraud, Italy–China money transfers
- Prosecutors described the trojan as decisive
- 22 arrests, ~€300 million seized

When the guardrails are questioned

~90

users reportedly targeted

20+

countries

0

clicks required (zero-click)

graphite_case.log

January 2025: WhatsApp detected a surveillance campaign using **Graphite**, spyware developed by **Paragon Solutions.**

- Government-grade commercial spyware platform, sold through high-value contracts
- Targets included journalists and members of civil society
- WhatsApp detected and disrupted the campaign, and notified affected users
- Italian targets reportedly included Luca Casarini, Giuseppe Caccia and Francesco Cancellato
- **Casarini and Caccia were legally investigated in the “Mare Jonio” case. Attribution for Cancellato remains unsolved.**

Spyware vs. civil society: a track record

Case	Target(s)	Spyware / Vendor	What happened
Bahrain, 2012	Political activists	FinFisher / Gamma International	Malicious attachments sent to Bahraini activists contained surveillance software with characteristics consistent with FinFisher.
Hacking Team cases	Journalists, activists, political opponents	RCS / Hacking Team	Researchers linked Hacking Team tools to operations targeting civil-society figures in several countries.
Ahmed Mansoor, UAE, 2016	Human-rights activist	Pegasus / NSO Group	Suspicious SMS links exploited three iOS zero-days. Uncovered by Citizen Lab and Lookout.
Mexico, 2016–2017	Journalists, activists, public-health advocates	Pegasus / NSO Group	Citizen Lab documented multiple Pegasus-linked campaigns against Mexican civil society.
Omar Abdulaziz, 2018	Saudi dissident living in Canada	Pegasus / NSO Group	Phone reportedly compromised, potentially exposing communications with journalist Jamal Khashoggi.
WhatsApp attack, 2019	~1,400 users incl. journalists, activists, lawyers	Pegasus / NSO Group	A WhatsApp calling vulnerability was exploited without the target needing to answer the call.
Pegasus Project, 2021	Journalists, politicians, activists, lawyers, dissidents	Pegasus / NSO Group	Leaked list of 50,000+ numbers. Amnesty found Pegasus traces on 37 of 67 devices examined.

[03]

Case Study

How we found a State Trojan inside a device
…and how that malware works.

// no IOCs today: the operation is still live!

wow.gif



We didn't know for sure if the device was infected



01 · The context

The client was involved in an investigation, later resulting in full clearance.



02 · The ask

Determine whether any residual surveillance implants were still active, assess their presence, and evaluate whether they could be removed.



03 · First move

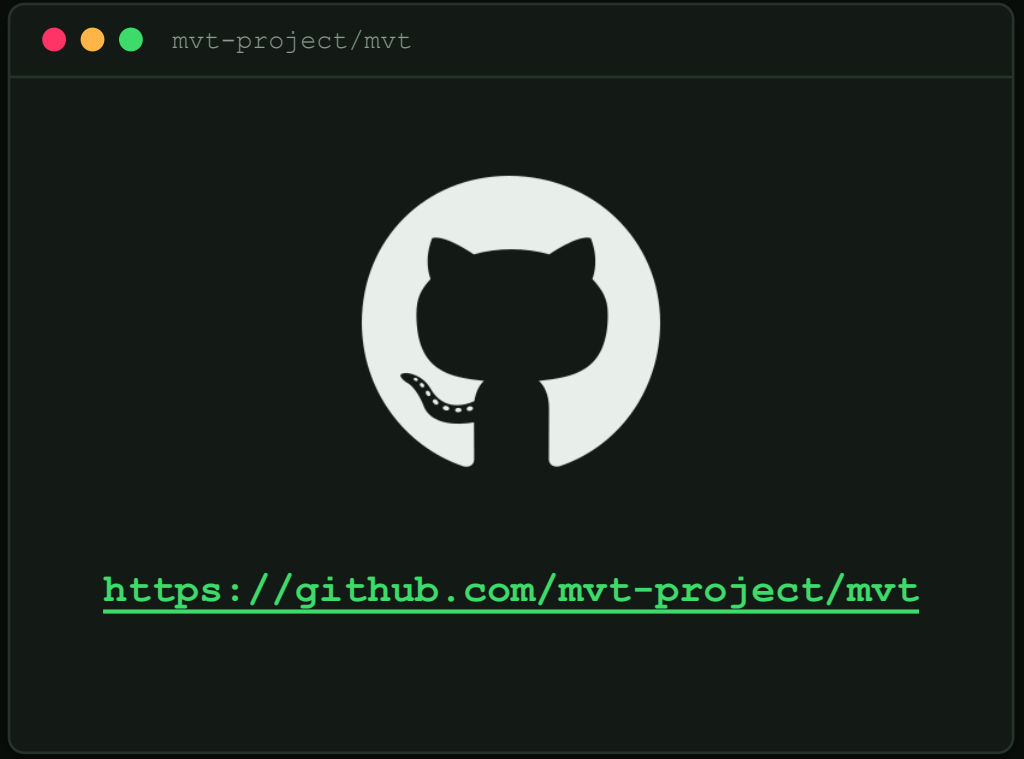
A basic triage of the device, to see if any app stood out.

Step 1: Mobile Verification Toolkit (MVT)

As a first step, we analysed the device with MVT.

Released in 2021 by **Amnesty International's Security Lab** to identify traces of compromise in the context of the **Pegasus Project.**

Free, open source, and the first thing to reach for when someone asks “am I being watched?”



[03] CASE STUDY

MVT: something looks off

mvt-android // output

```
INFO - Found a receiver monitoring telephony state/incoming calls: "com.tencent.mm/android.system.telephony.receiver.CallReceiver"
INFO - Found a receiver to intercept incoming SMS messages: "com.tencent.mm/android.system.telephony.receiver.SmsReceiver"
INFO - Found installed accessibility service "com.tencent.mm/android.system.telephony.services.AccessibilityServiceImpl"
INFO - Package com.tencent.mm with REQUEST_INSTALL_PACKAGES permission
INFO - Third-party package "com.tencent.mm" requested 13 potentially dangerous permissions
INFO - Found non-system package with name "com.tencent.mm" installed by "com.tencent.mm" on 2022-10-20 10:23:09
```

An app with package name `com.tencent.mm` (WeChat's package name) is monitoring calls and SMS, and has registered as an **accessibility service**.

But WeChat was NOT installed on the device.

[03] CASE STUDY

A strange SMS

sms_inbox // installation date


```
{
    "address": "+39 [redacted]",
    "body": "TIM: Gentile cliente, di seguito il link per seguire la procedura: https://assistenza-tim.[redacted].com/__/30/[redacted]",
    "date": "1666253825244",
    "date_sent": "1666253825000",
    "status": "-1",
    "type": "1",
    "recipients": [
        "+39[redacted]"
    ],
    "read": "1",
    "isodate": "2022-10-20 08:17:05.244000",
    "direction": "sent",
    "links": [
        "https://assistenza-tim.[redacted].com/__/30/[redacted]"
    ]
},
```


Among the SMS received on the date of installation, one message looks pretty suspicious.

HYPOTHESIS

No call logs, but the SMS suggests the user got a call from someone impersonating their carrier's support: TIM.

A brief overview of the domains

whois // domain



Whois Record for [redacted]

— Domain Profile

Registrar	GoDaddy.com, LLC IANA ID: 146 URL: https://www.godaddy.com,http://www.godaddy.com Whois Server: whois.godaddy.com abuse@godaddy.com (p) +1.4806242505
Registrar Status	clientDeleteProhibited, clientRenewProhibited, clientTransferProhibited, clientUpdateProhibited
Dates	2,116 days old Created on 2020-12-10 Expires on 2026-12-10 Updated on 2025-12-11

whois // registrant

```
Registrant Name: Registration Private
Registrant Organization: Domains By Proxy, LLC
Registrant Street: DomainsByProxy.com
Registrant Street: 100 S. Mill Ave, Suite 1600
Registrant City: Tempe
Registrant State/Province: Arizona
Registrant Postal Code: 85281
Registrant Country: US
Registrant Phone: +1.4806242599
```

2020

Registration year. Still online today.

A brief overview of the domains

dns // subdomains

windtre.[redacted]	[redacted]	ARUBA-ASN - Aruba S.p.A., IT Italy
assistenza-tim.[redacted]	[redacted]	ARUBA-ASN - Aruba S.p.A., IT Italy
kena.[redacted]	[redacted]	ARUBA-ASN - Aruba S.p.A., IT Italy
ho.[redacted]	[redacted]	ARUBA-ASN - Aruba S.p.A., IT Italy
fastweb.[redacted]	[redacted]	ARUBA-ASN - Aruba S.p.A., IT Italy
assistenzaposte.[redacted]	[redacted]	ARUBA-ASN - Aruba S.p.A., IT Italy

> Carrier lookalikes

Subdomains pose as other Italian carriers, hinting the operation is based in Italy.

> Italian hosting

Infrastructure hosted on Aruba.

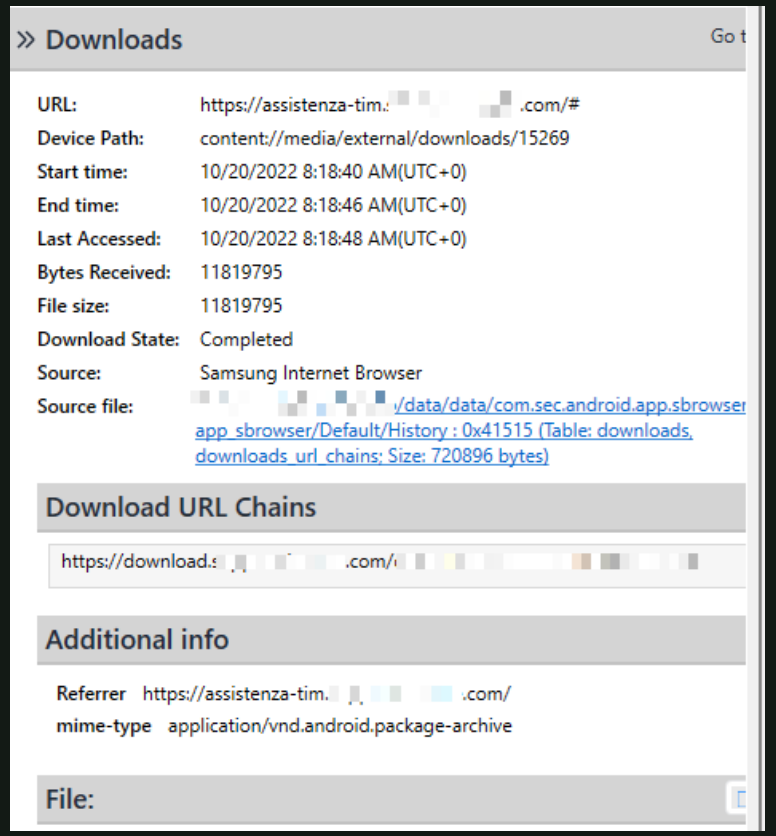
> Built to last

Online since 2020. Not what you'd expect from a fly-by-night operation.

[03] CASE STUDY

An APK has been downloaded

samsung_internet // downloads



+1 min

after the SMS from "TIM support"

Samsung Internet browser history shows an APK being downloaded one minute after the SMS arrived.

APK basic information

apk_info.txt

```
package     com.tencent.mm   # WeChat (!)
label       System
version     3.0.7699
signature   self-signed

  └─ CN=Android Developer
  └─ OU=Telegram
  └─ O=Telegram
  └─ L=Unknown  ST=Unknown  C=Unknown
```

Why com.tencent.mm?

We have two theories behind the use of WeChat's package name:

Theory #1

Masquerading / evasion

Borrow the identity of a hugely popular app so the implant blends in.



Theory #2

Whitelisting by Chinese OEMs

Chinese OEMs (OPPO, Xiaomi, OnePlus, etc.) whitelist Chinese apps' package names for power-management or background-execution exemptions.

[03] CASE STUDY

The “Permissions Tutorial”

01



Found in RE

References to a “Permissions Tutorial” in the decompiled code.

02



Needs its C2

The app must be opened and reach its main server to get its configuration.

03



So we faked it

We built a mock server that serves the configuration it expects.

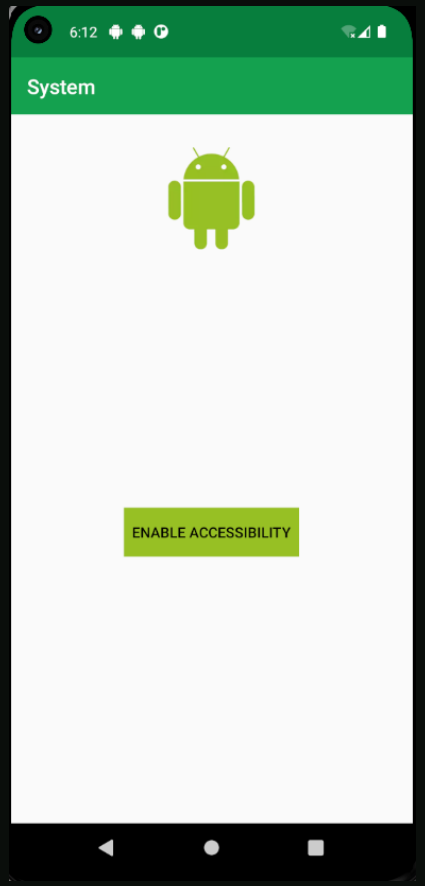
04



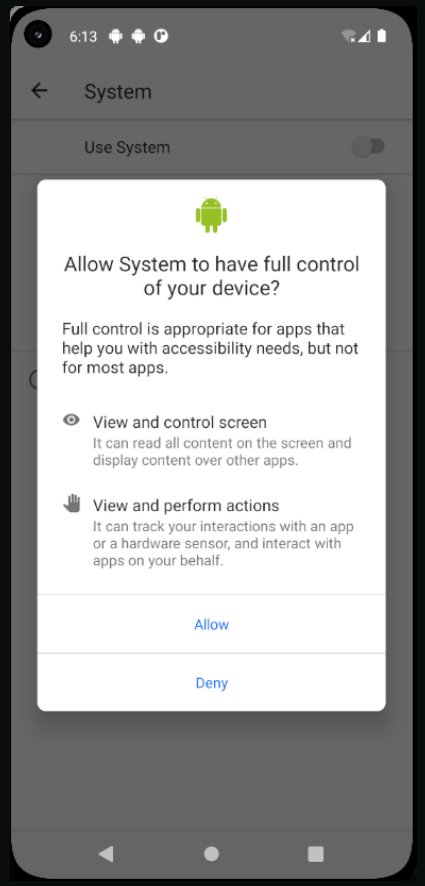
Tutorial unlocked

…and it turned out to be surprisingly “sophisticated”...

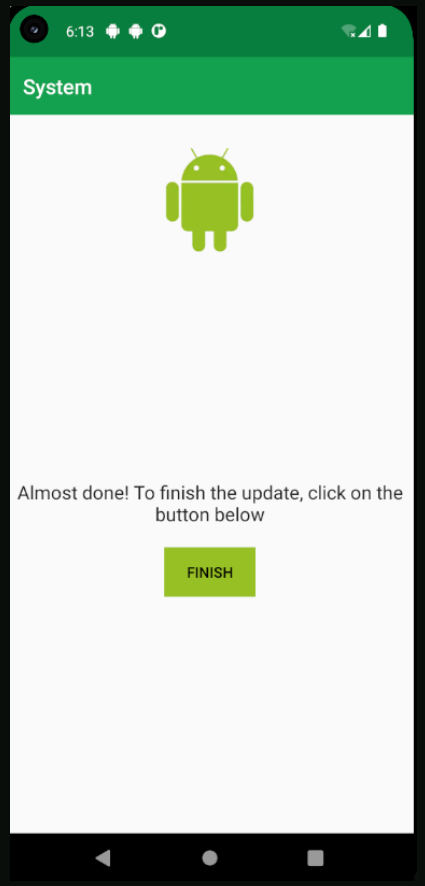
The "Permissions Tutorial", live



01 · App posing as "System"



02 · "Allow full control"



03 · "Finish the update"

Yeah, maybe it wasn't so sophisticated...

A fake "System" update walks the victim through handing over full control of the device.

What can it do? 1/5

capabilities.log // 1 of 5 // surveillance

Surveillance & monitoring	What it does
Audio surveillance	Records microphone audio and captures VoIP call activity. Does not intercept conventional cellular calls.
Camera surveillance	Captures photos using the device camera.
Screen surveillance	Captures screenshots, visible screen content, and activity from the foreground application.
Communications surveillance	Captures visible conversations and notifications from WhatsApp, Telegram, Facebook/Messenger, Instagram, Signal, Viber, and imo. Identifies VoIP calls and participants.
Browser surveillance	Collects URLs visited through Chrome.

What can it do? 2/5

capabilities.log // 2 of 5 // collection

Device & data collection	What it does
Location tracking	Collects GPS location data.
Device profiling	Collects device information and inventories installed applications.
Contact collection	Extracts accessible contact information.
File collection	Inventories accessible storage and collects selected files, media, and chat attachments.

What can it do? 3/5

capabilities.log // 3 of 5 // remote_access

Remote access & device control	What it does
Remote command execution	Receives commands and executes shell commands within the application's privilege context.
Remote configuration	Remotely modifies malware collection and operational settings.
Payload extensibility	Downloads code patches, modules, or plugins to extend or modify functionality.
Accessibility-service abuse	Uses Android Accessibility capabilities to automate UI interactions, modify settings, grant permissions, and activate device-administrator functionality where supported.

What can it do? 4/5

capabilities.log // 4 of 5 // persistence

Persistence, evasion & defence impairment	What it does
Persistence	Restarts after device boot and attempts to obtain battery-optimization exemptions.
Application concealment	Hides its launcher entry to reduce visibility to the user.
Security-tool interference	Redirects users away from selected security, cleanup, or uninstall interfaces.
Warning suppression	Suppresses selected warning notifications and automatically dismisses targeted system dialogs.

What can it do? 5/5

capabilities.log // 5 of 5 // c2

Command & control / exfiltration	What it does
C2 communication	Exchanges commands and operational data through WebSocket and HTTP channels.
Data exfiltration	Transfers collected information and files to remote infrastructure.
Transport protection	Uses message authentication and encrypted file payloads during communication.

[03] CASE STUDY

What was it actually monitoring?

collection_config

APPS

- WhatsApp
- WhatsApp Business
- Telegram

DATA

- Calls
- Conversations
- Files / attachments
- Notifications

ARTIFACTS FOUND

- Microphone ambient recordings

153

distinct WhatsApp chat identifiers in the malware's local storage

`$ status` implant: **installed & running** · operation: **apparently closed server-side**

Extra: who was behind this?

We Won't Tell You!

But...

dns // records

MX Records

10 mail.[redacted] [redacted] ARUBA-ASN - Aruba S.p.A., IT

Italy

[04] DEFENCE

How can we defend ourselves against unlawful surveillance?



Update everything

Keep your browser and mobile OS up to date.



Think before you tap

Be mindful of links from strangers.



Notice the weird

Watch for changes in how your device behaves (e.g. battery drain).



Check the traffic

Verify phone traffic against known C2s: github.com/SpyGuard



No sideloading

Avoid installing APKs from outside well-known app stores.

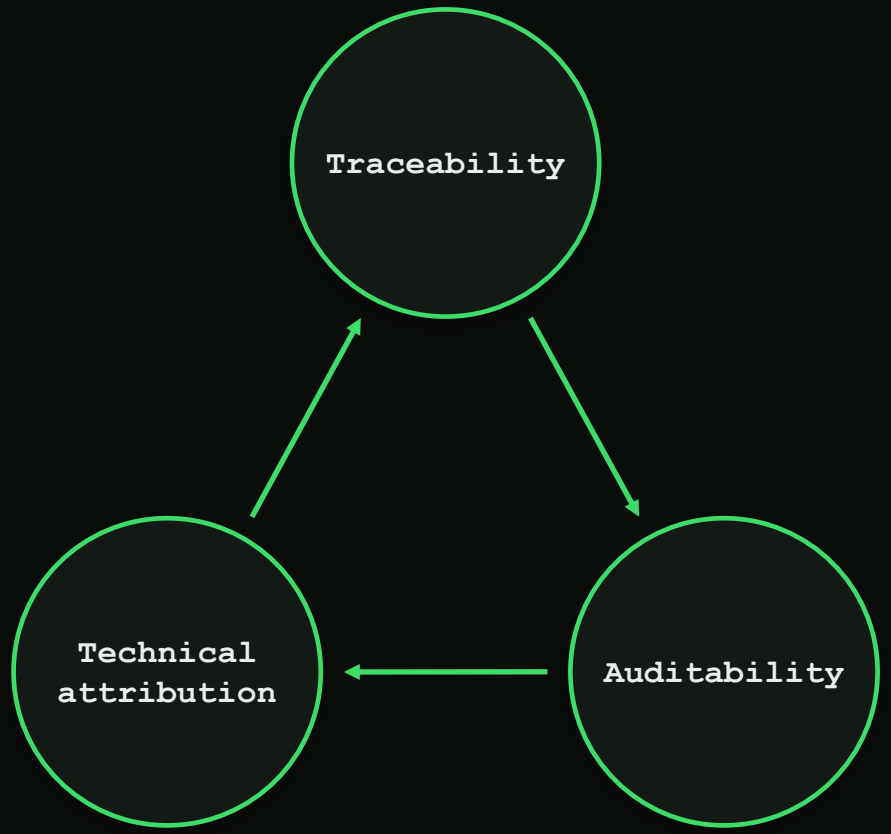
Lawful access requires technical accountability

Regulation defines who is allowed to use the tool.

Cybersecurity must prove how it was actually used.

audit_questions.sh

```
? Can we audit the logs?
? What data was access?
? Can the operator be attributed afterwards?
? Was it lawfully used?
```



$ echo "thanks" && exit 0

Thanks!

Q & A

~/contacts



@peterwander

@spawntty

ROMHACK 2026 CAMP

>_apt/get.defence